

Control ID	Control Name
------------	--------------

A8.2	Priviledge access Rights
------	--------------------------

A8.24	Use of Cryptography
-------	---------------------

A8.32	Change Management
-------	-------------------

A5.3	Segregation of Duties
------	-----------------------

A5.15 Access Control

A5.16 Identity Management

A8.5 Secure Authentication

A8.15 Logging

A6.3 Information Security Awareness, Education and Training

A6.6 Confidentiality or Non-disclosure agreements

Explanation

Privileged access rights ensure that users only receive elevated permissions when required for a specific task or role. These rights are tightly controlled, time-bound, and reviewed to prevent unnecessary or excessive access.

Cryptography ensures the confidentiality and integrity of information by encrypting data at rest and in transit. It protects sensitive information from being accessed or altered by unauthorised parties

Change Management ensures that any modifications to systems, applications, or processes are planned, reviewed, approved, and documented. The goal is to prevent unplanned outages, security weaknesses, or disruption to business operations.

Segregation of Duties (SoD) ensures that no single individual has end-to-end control over a critical process. By separating responsibilities (e.g., request, approve, implement, review), organisations reduce the risk of fraud, manipulation, or accidental misuse of systems and data.

Access control ensures that users, devices, and applications can only access the information and systems they are authorised to use. It enforces the principle of least privilege and prevents excessive or unnecessary access.

Effective access control covers:

User access provisioning and deprovisioning

Role-Based Access Control (RBAC)

Least privilege & need-to-know

Periodic access reviews

Authentication & authorization policies

Identity Management ensures that every user identity in the organisation is created, maintained, modified, and removed in a controlled and secure way. It covers the entire identity lifecycle — Joiner, Mover, Leaver (JML) — and ensures users only have the access they need, for as long as they need it.

This includes:

Provisioning & deprovisioning

Role changes (movers)

Privileged identity lifecycle

Credential management

Strong authentication & verification

Secure authentication ensures that users, devices, and services prove their identity using strong and reliable methods before gaining access. It protects against credential theft, brute force attacks, phishing, and unauthorised access.

It includes:

Strong password standards

Multi-Factor Authentication (MFA)

Passwordless or certificate-based authentication

Secure verification for privileged accounts

Controls against brute-force and session hijacking

Logging ensures that security-relevant events are recorded, protected, and monitored so the organisation can detect suspicious activity, investigate incidents, and maintain accountability.

Logs help identify:

unauthorised access attempts

system changes

configuration modifications

anomalous behaviour

potential vulnerabilities

Proper logging is essential for threat detection, forensics, and compliance

This control ensures that all employees, contractors, and relevant third parties receive ongoing security awareness and training. The goal is to build a security-minded culture where people understand threats, recognise risks, and follow secure behaviour in their day-to-day work.

Training covers areas such as:

- phishing and social engineering

- password hygiene

- data handling and classification

- reporting suspicious activity

- secure use of corporate systems

- insider threat awareness

It ensures every person understands their security responsibilities.

Confidentiality or NDA agreements ensure that employees, contractors, and third parties understand their obligation to protect sensitive information. They formally bind individuals to maintain confidentiality during and after their engagement with the organisation. This applies to:

- employees

- contractors

- vendors

- consultants

- temporary staff

NDA's help enforce confidentiality, integrity, and proper handling of sensitive data.

How company implements

Privileged access is granted only through a formal approval workflow (manager or system owner approval). Access is provisioned via a privileged access management (PAM) process, often using time-bound or just-in-time elevation. All privileged activities are logged and periodically reviewed to ensure access is used appropriately.

The organisation applies encryption standards (e.g., AES-256, TLS 1.2+) to protect sensitive data in storage and transmission. Digital certificates and key management processes are used to authenticate systems and secure communications.

The organisation uses a formal change management process where changes are raised as change requests, assessed for risk and impact, approved by authorised stakeholders, tested in a controlled environment, scheduled during maintenance windows, and implemented with a documented rollback plan. All changes are logged and reviewed for completeness and compliance.

The organisation defines role-based access so that critical tasks are split across multiple people or teams. Approvals, system changes, financial transactions, and access grants all follow a dual-control process (e.g., maker-checker). Access rights are regularly reviewed to ensure no conflicting roles are assigned to the same user.

Risk if missed

If privileged access is not controlled, users may retain unnecessary administrative rights, leading to unauthorised system changes, data breaches, or full environment compromise.

If cryptographic controls are not implemented, sensitive data can be intercepted, modified, or accessed in plain text, leading to data breaches, loss of integrity, and regulatory non-compliance.

Without change management, unauthorised or poorly planned changes can cause system outages, data loss, security vulnerabilities, and non-compliance with regulatory requirements. Lack of a rollback plan can leave systems unstable and significantly impact business operations.

If SoD is not enforced, employees may gain excessive control over critical processes, leading to fraud, unauthorised changes, financial loss, data tampering, or major compliance breaches (e.g., ISO 27001, SOC2, internal audit findings).

The organisation establishes an access control policy defining how access is requested, approved, granted, and reviewed. Access is aligned to job roles using RBAC.

Controls are applied through IAM tools (e.g., Entra ID, Okta), MFA, SSO, and logging/monitoring systems.

Routine practices:

Access requests require manager + system owner approval

Privileged access is tightly controlled through PAM

Access is removed immediately during offboarding

Quarterly access reviews validate who still needs what

MFA enforced for all high-risk systems

If access control is weak or inconsistent, it can result in:

Unauthorised access to sensitive systems or data

Data breaches or exposure of customer information

Fraud, financial loss, and system manipulation

Regulatory and audit failures (ISO 27001, SOC2, CPS 234)

Reputational damage and loss of customer trust

The organisation establishes identity governance processes and automates the JML lifecycle through IAM tools (e.g., Entra ID, Okta). HR systems (e.g., Workday) trigger automatic provisioning and deprovisioning to prevent orphaned accounts.

Typical implementations include:

Enforcing MFA & SSO

Using role-based access and least privilege

Automating identity workflows

Running periodic access reviews

Applying Zero Trust (continuous verification)

Using PAM for high-risk privileges

Identity-related logs are monitored to detect suspicious activity such as anomalous sign-ins, privilege escalation, or unusual access patterns

If identity management is weak or inconsistent, the organisation faces:

Orphaned accounts remaining active after staff leave

Privilege creep (users keep gaining access they no longer need)

Credential misuse by insiders or attackers

Compliance violations (ISO 27001, SOC2, CPS 234)

Data breaches from unauthorised access

Increased risk of phishing, account takeover, and ransomware

The organisation enforces MFA for all users, with stricter policies for privileged accounts. Password policies define the minimum length, complexity, and expiry requirements, and prevent the reuse of old credentials.

Additional practices include:

Account lockout after repeated failed attempts

Enforcing passwordless authentication (FIDO2, biometrics)

Using secure authentication protocols (OAuth, SAML, Kerberos)

Monitoring risky sign-ins and enforcing conditional access

Encrypting credentials at rest and in transit

Disallowing weak or breached passwords via password check tools

These measures ensure authentication cannot be bypassed or easily compromised.

If authentication controls are weak or outdated, attackers can:

Gain unauthorised access using stolen or guessed passwords

Compromise privileged accounts

Move laterally across systems

Steal sensitive data

Cause financial loss, outages, and legal/regulatory issues

Weak authentication directly increases the risk of ransomware, insider misuse, account takeover, and loss of customer trust.

The organisation centralises all logs using a SIEM (e.g., Splunk, Sentinel, QRadar) to ensure consistent collection, correlation, and monitoring.

Implementation includes:

Collecting logs from servers, applications, network devices, cloud services, IAM systems, and endpoints

Using a standard log format (JSON, CEF, Syslog)

Protecting logs from tampering using integrity controls

Encrypting logs at rest and in transit

Applying role-based access so only authorised staff can view or export logs

Setting retention periods according to policy and regulatory requirements

Creating alerts for suspicious or high-risk events

Integrating logs into incident response workflows

If logging is weak or inconsistent, the organisation may:

Completely miss early signs of an attack

Fail to detect compromised accounts or lateral movement

Lose evidence needed for investigations

Become unable to confirm what data was accessed or stolen

Face extended breaches due to delayed detection

Fail audits (ISO 27001, SOC2, CPS 234)

Suffer major financial and reputational damage

Logging is a core part of security visibility — without it, you're blind.

The organisation delivers regular security training through:

- onboarding induction for new staff
- annual mandatory security training
- targeted training for high-risk roles (e.g., IAM, finance, developers)
- simulated phishing campaigns
- refresher micro-learning throughout the year
- policy acknowledgement tracking
- role-based training aligned to job function

Completion rates are monitored, and non-compliant staff are followed up or re-trained.

If awareness and training are weak, users become the biggest vulnerability.

This leads to:

- increased phishing success
- credential compromise
- accidental data exposure
- mishandling of sensitive information
- higher incident rates
- non-compliance with ISO 27001, SOC2, CPS 234

A lack of training directly increases both insider and external attack success.

The organisation:

- requires all employees to sign confidentiality agreements during onboarding
- ensures vendors and contractors sign NDAs before accessing systems or data
- includes confidentiality clauses in employment contracts and supplier contracts
- maintains records of signed agreements
- reinforces obligations during annual policy refresh
- ensures NDAs cover data handling, IP protection, privacy obligations, and post-employment restrictions
- Legal and HR teams maintain templates and ensure they align with regulation and organisational policy.

Without strong NDAs, the organisation could face:

- unauthorised disclosure of sensitive or personal data
- leaking of intellectual property
- insider misuse or data theft
- major legal and compliance issues
- reputational damage
- loss of competitive advantage
- NDAs provide legal protection and set clear expectations for all parties handling sensitive information.